

ISC 2019 第七届互联网安全大会

怎么样卖ODAY漏洞给政府和攻击型安全公司

莫尔·施瓦茨

以色列Q-RECON公司漏洞经纪人

小鹅助理



扫码添加小鹅助理，与数万科技圈人士
分享重量级活动PPT、干货培训课程、高端会议免费
门票



莫尔·施瓦茨
Maor Shwartz

以色列Q-recon公司漏洞经纪人
Vulnerability broker from Q-recon





Selling 0-days to governments and offensive security companies

Maor Shwartz



Agenda

- Who is this talk for?
- My Story
- Overview
- Who is selling 0-days to governments / offensive security companies?
- The process of selling 0-days
- How to sell 0-days?
- Tips for beginners



金中心

My story – **The Beginning**

- Founded a vulnerability brokerage company called Q-recon
- Had quite a few researchers working with me
- Attained some major clients
- After a few successful moves started to get attention
 - Sold 0-days
 - Found jobs for a few researchers





My Story – The End (?)

Internet Security Conference 2019

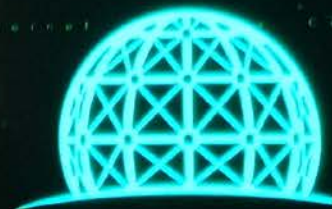
- Got on a major player's radar (will not reveal the name).
Effectively threatened in a broad daylight at a café.
- Not worth the risk, closed Q-recon

Internet Security Conference



Regular Development issues

- In traditional software companies:
 - The problem is linear
 - When the company encounters a technology problem – they hire an army of developers in order to solve that problem





The uniqueness of vulnerabilities research

- Finding vulnerabilities is an art, not a science (Most of the time) That's why it's a multi million dollars industry
- You can hire a lot of vulnerability researchers, spend millions and find nothing





History

In the past 5 years the 0-day market has transformed drastically

Increase in number of:

Brokerage companies

Offensive security companies

Conferences

Competitions

Bug bounty programs

Budgets

Stepping out of the shadows

(No more whispering in dark alleyways)



Who is interested in 0-days?



全中心



Cyber security
companies
(defense)

Bug bounty
programs

Bug bounty
platform



Vulnerability
brokers

Competitions
Pwn2Own /
PWN0RAMA /
Hack2Win /
Zer0Fest



Offensive
Security
Companies

Government

Criminals



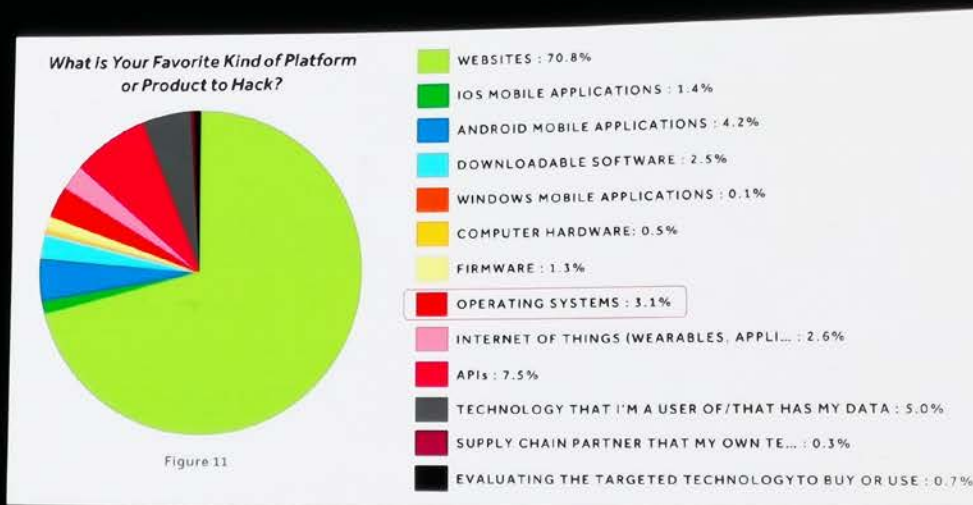
Vulnerability researchers – overview (HackerOne - 2018)



166,000
Registered Hackers

72,000 vulnerabilities
submitted

70% of the reported
vulnerabilities are focused on
web





Vulnerability researchers – overview (HackerOne - 2019)

WHAT DO YOU HACK?

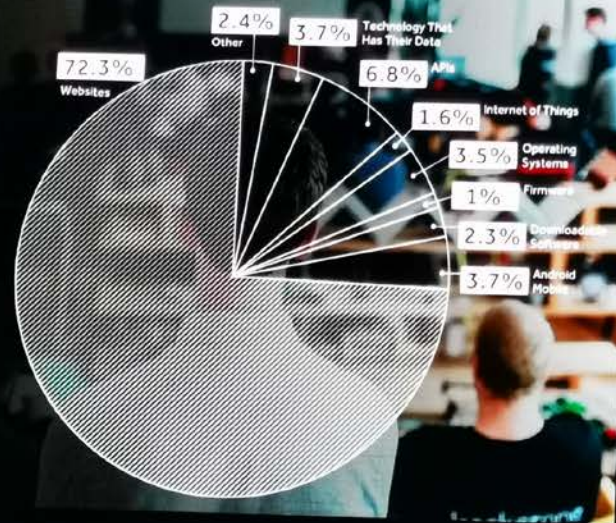


Figure 10

~300,000
Registered Hackers

~100,000 vulnerabilities
submitted



73% of the reported
vulnerabilities are focused on
web



Vulnerability researchers – overview (bugcrowd - 2018)

AMOUNT PAID BY TARGET



SUBMISSIONS PAID BY TARGET



■ WEBSITE ■ ANDROID ■ API ■ HARDWARE ■ IOS ■ IOT

■ WEBSITE ■ ANDROID ■ API ■ ■ ■ IOT



Cross-Site Scripting (XSS) Reflected (P3), was the top vulnerability submitted this year via the Crowdcontrol™ platform.



The majority, **13%** of all submissions paid out last year were for vulnerabilities classified as **Cross-Site Scripting (XSS) Stored**.

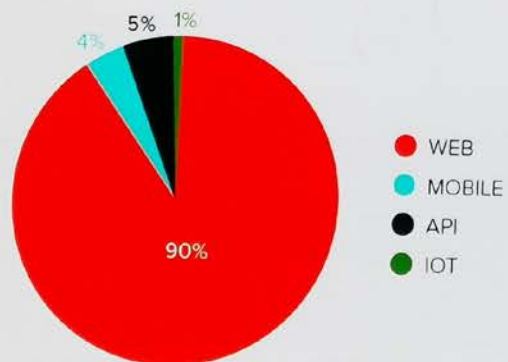


Vulnerability researchers – overview (bugcrowd - 2019)

92% increase in total vulnerability submissions

TOP TARGETS BY NUMBER OF SUBMISSIONS 2018

SUBMISSIONS INCREASED BY TARGET 2018



↑ 99%	Web
↑ 141%	Mobile
↑ 101%	API
↑ 384%	IoT



There are also high-end researchers that contribute to the community

iOS 12

Released September 17, 2018

Accounts

Available for: iPhone 5s and later, iPad Air and later, and iPod touch 6th generation

Impact: A local app may be able to read a persistent account identifier

Description: This issue was addressed with improved entitlements.

CVE-2018-4322: Min (Spark) Zheng, Xiaolong Bai of Alibaba Inc.

Auto Unlock

Available for: iPhone 5s and later, iPad Air and later, and iPod touch 6th generation

Impact: A malicious application may be able to access local users AppleIDs

Description: A validation issue existed in the entitlement verification. This issue was addressed with improved validation of the process entitlement.

CVE-2018-4321: Min (Spark) Zheng, Xiaolong Bai of Alibaba Inc.

Entry added September 24, 2018



P0



安全中心

Whitehats

There are a lot of
“vulnerability researchers”

Most are focused on low-
hanging fruit
Quick and easy money
Bug bounties

- The high-end researchers:
- (Sometimes) Ideologically motivated
 - Working in Cyber security companies / research teams (PR motivated)



Who is interested in 0-days?



Cyber security
companies
(defense)- PR

Bug bounty
programs

Bug bounty
platform



Vulnerability
brokers

Competitions
Pwn2Own /
PWNoRAMA /
Hack2Win /
Zer0Fest



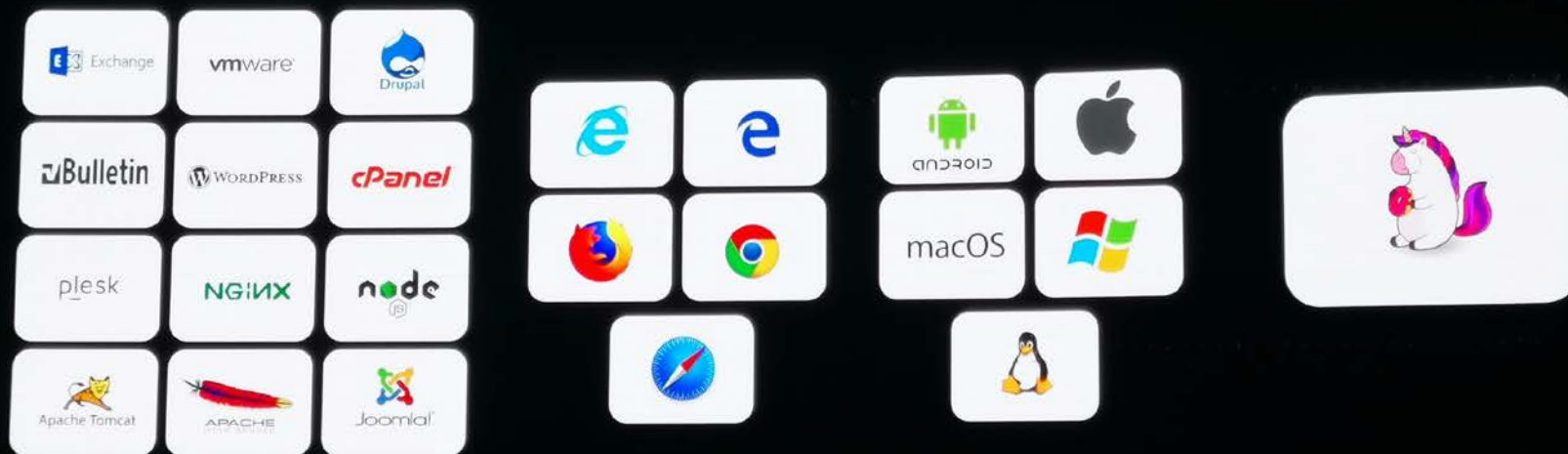
Offensive
Security
Companies

Government

Criminals



The High-End Market



*No user interaction pre-auth RCE or LPE



The High-Rollers Table

End-product

Vector

- RCE + LPE + Persistence

Vulnerabilities

- RCE | LPE | Persistence

Component (parts in a chain)

- Info leak
- Mitigation bypass

Services

Dedicated research

- Freelancing

Workshops

Consulting

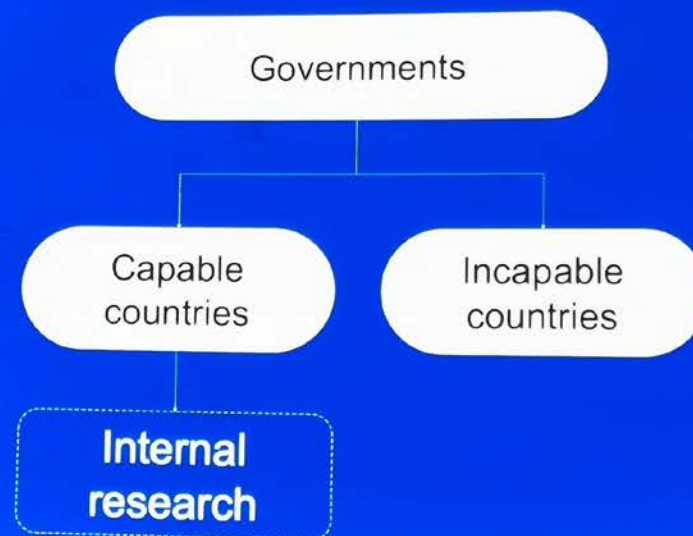
- Validate other researchers vulnerabilities

Support

- Exploit new versions



Companies vs Governments

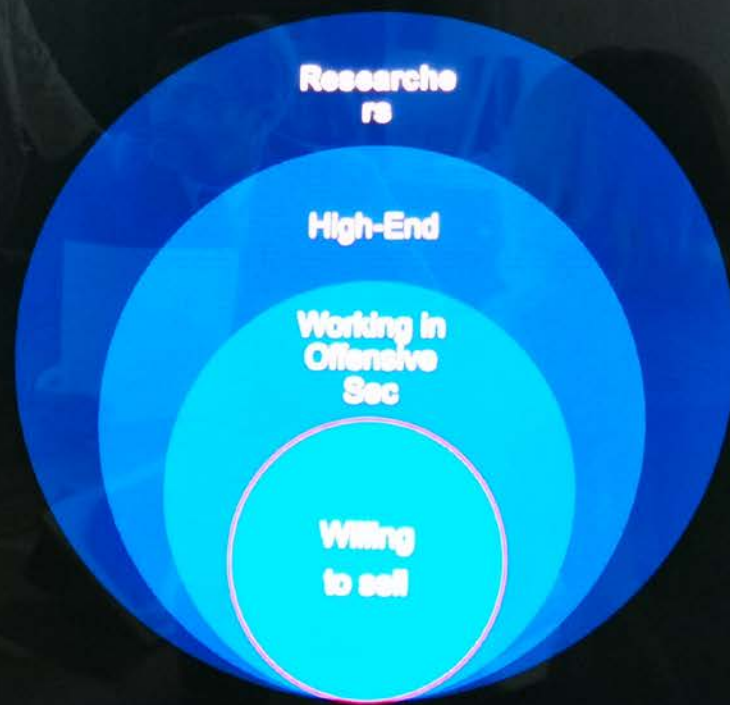




**How are they
getting them
0-days**



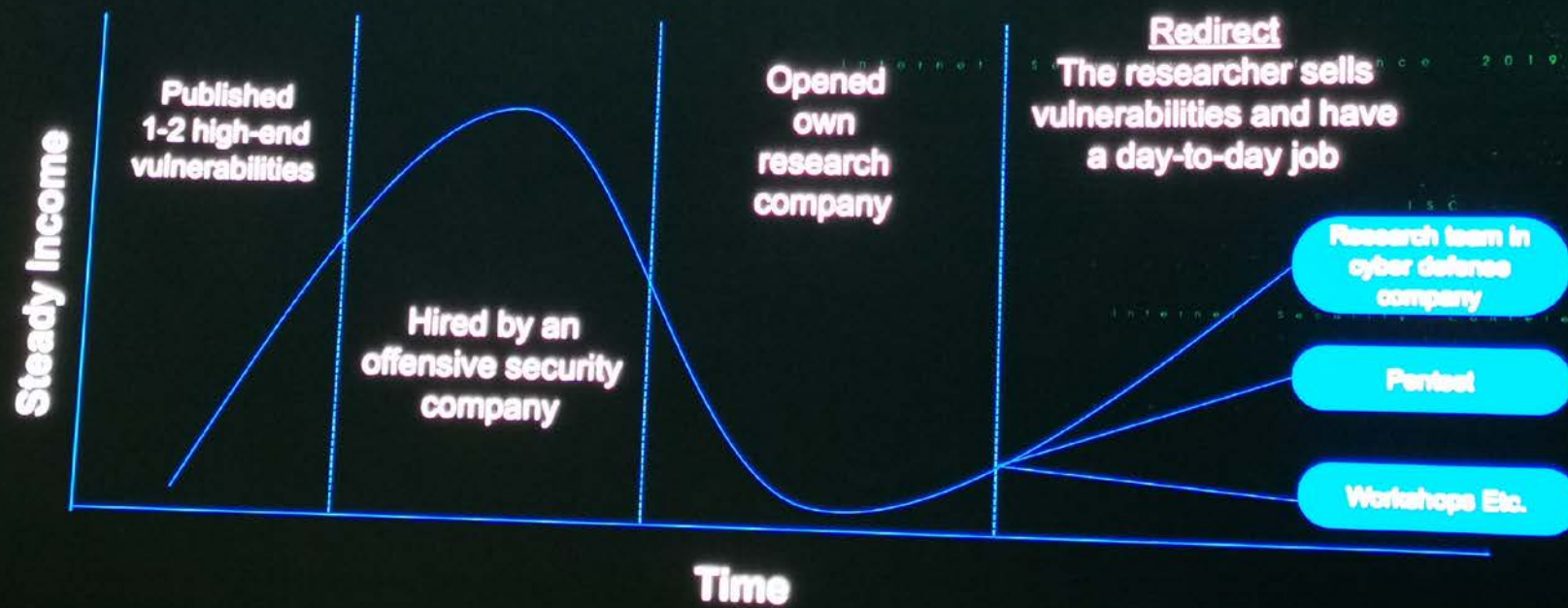
Researchers by groups



网络安全中心



The researcher journey (Based on my experience)



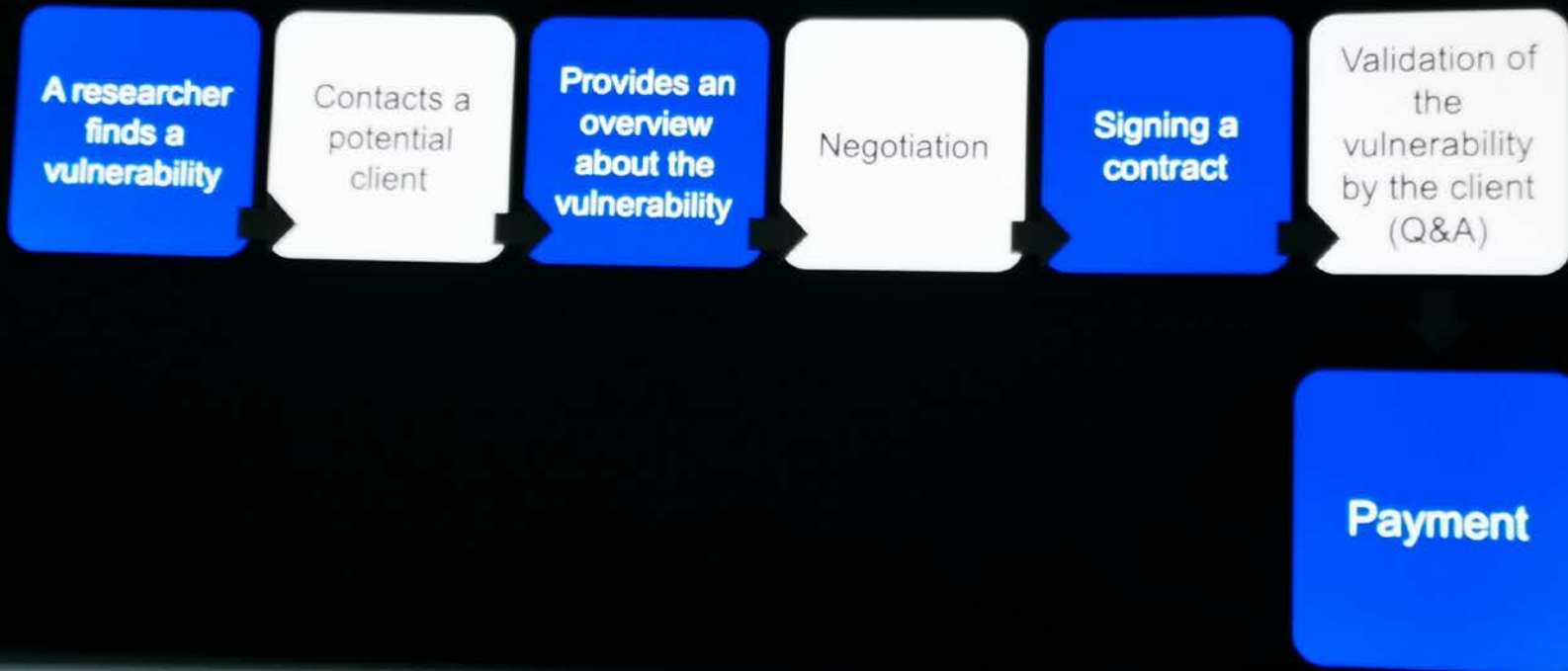


What we learned so far?

- What kind of products governments and offensive security companies are interested in
- The different products / services researchers can provide
- Governments VS Companies
- The researchers characteristics



The sales process - overview





网络安全中心

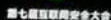
Payouts

- As a researcher you expect to get paid more than the vendor bug bounty program

There is no single pricelist

- Competitions (pwn2own / PWN0RAMA)
- Rumors – other researchers that sold
- Hacking Team like incidents

Zerodium transformed the optics for Oday acquisition, devil is in the details.



RJB: Remote Jailbreak with Persistence
RCE: Remote Code Execution
LPE: Local Privilege Escalation
SBX: Sandbox Escape or Bypass

 iOS
 Android
 Any OS

ZERODIUM Payouts for Mobiles*

RJB: Remote Jailbreak with Persistence
 RCE: Remote Code Execution
 LPE: Local Privilege Escalation
 SBX: Sandbox Escape or Bypass

iOS
 Android
 Any OS

Payout	Exploit	Platform
Up to \$1,500,000	iPhone RJB Zero Click	iOS
Up to \$1,000,000	iPhone RJB	iOS
Up to \$500,000	WeChat RCE+LPE	iOS/Android
	Viber RCE+LPE	iOS/Android
	FB Messenger RCE+LPE	iOS/Android
	Signal RCE+LPE	iOS/Android
	Telegram RCE+LPE	iOS/Android
	WhatsApp RCE+LPE	iOS/Android
	iMessage RCE+LPE	iOS
	SMS/MMS RCE+LPE	iOS/Android
	Email App RCE+LPE	iOS/Android
Up to \$200,000	Baseband RCE+LPE	iOS/Android
Up to \$100,000	Code Signing Bypass	iOS
	WiFi RCE+LPE	iOS/Android
	Media Files RCE	iOS/Android
	Documents RCE	iOS/Android
	LPE to Kernel	iOS/Android
	SBX for Chrome	Android
	Chrome RCE w/o SBX	Android
	SBX for Safari	iOS
	Safari RCE w/o SBX	iOS
Up to \$50,000	Code Signing Bypass	Android
	Secure Boot	iOS
	RCE via M4M	iOS/Android
	LPE to Root	iOS/Android
	Chrome UXSS/SOP	iOS/Android
	Safari UXSS/SOP	iOS
Up to \$25,000	TrustZone	Android
	Verified Boot	Android
	LPE to System	Android
	ASLR Bypass	iOS/Android
	kASLR Bypass	iOS/Android
	Seccomp Bypass	Android
	RKP Bypass	Android
	Knox Bypass	Android
Up to \$15,000	Information Disclosure	iOS/Android
	Passcode Bypass	iOS
	Touch ID Bypass	iOS
	PIN Bypass	Android

* All payouts are subject to change or cancellation without notice, at the discretion of ZERODIUM. All trademarks are the property of their respective owners.

2018/09 © zerodium.com



Payouts – behind the scenes

Different entities will offer different payouts for the same vulnerability

Warranty and Seller model matters

Complexity of
the system

Mitigations

Supply and
demand

Who is the
researcher

Deliverables

Generic

Exclusive /
Nonexclusive



网络安全中心



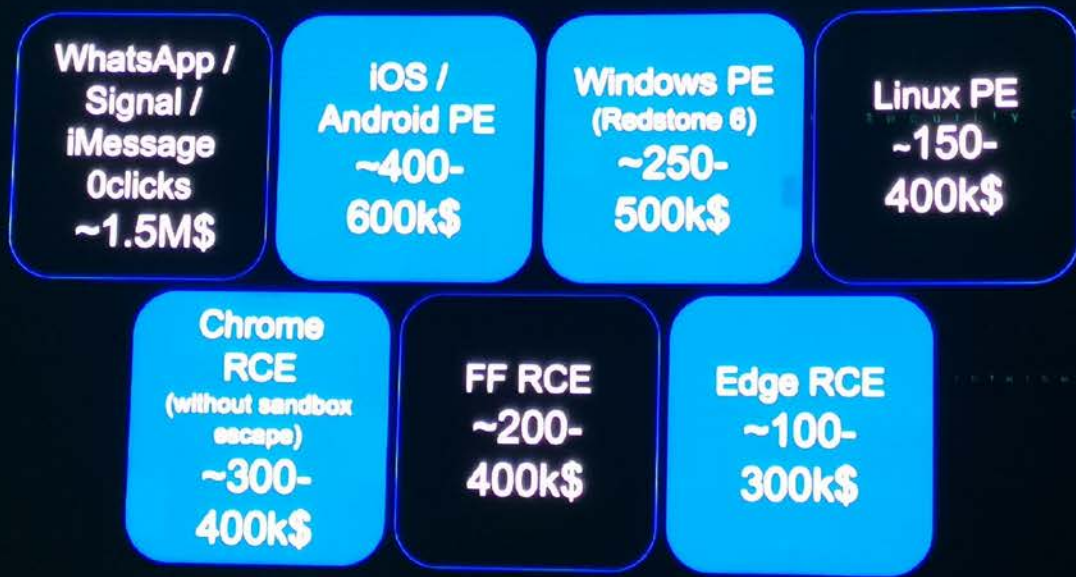
Payouts – Warranty and Seller model

- Company XXX could pay you 1.5 million
 - Its over 12 months
 - Give it to all their customers day 0 of the warranty

How much do you think will be captured of your 0day
1.5 million in reality?



Payouts – behind the scenes





NOTE

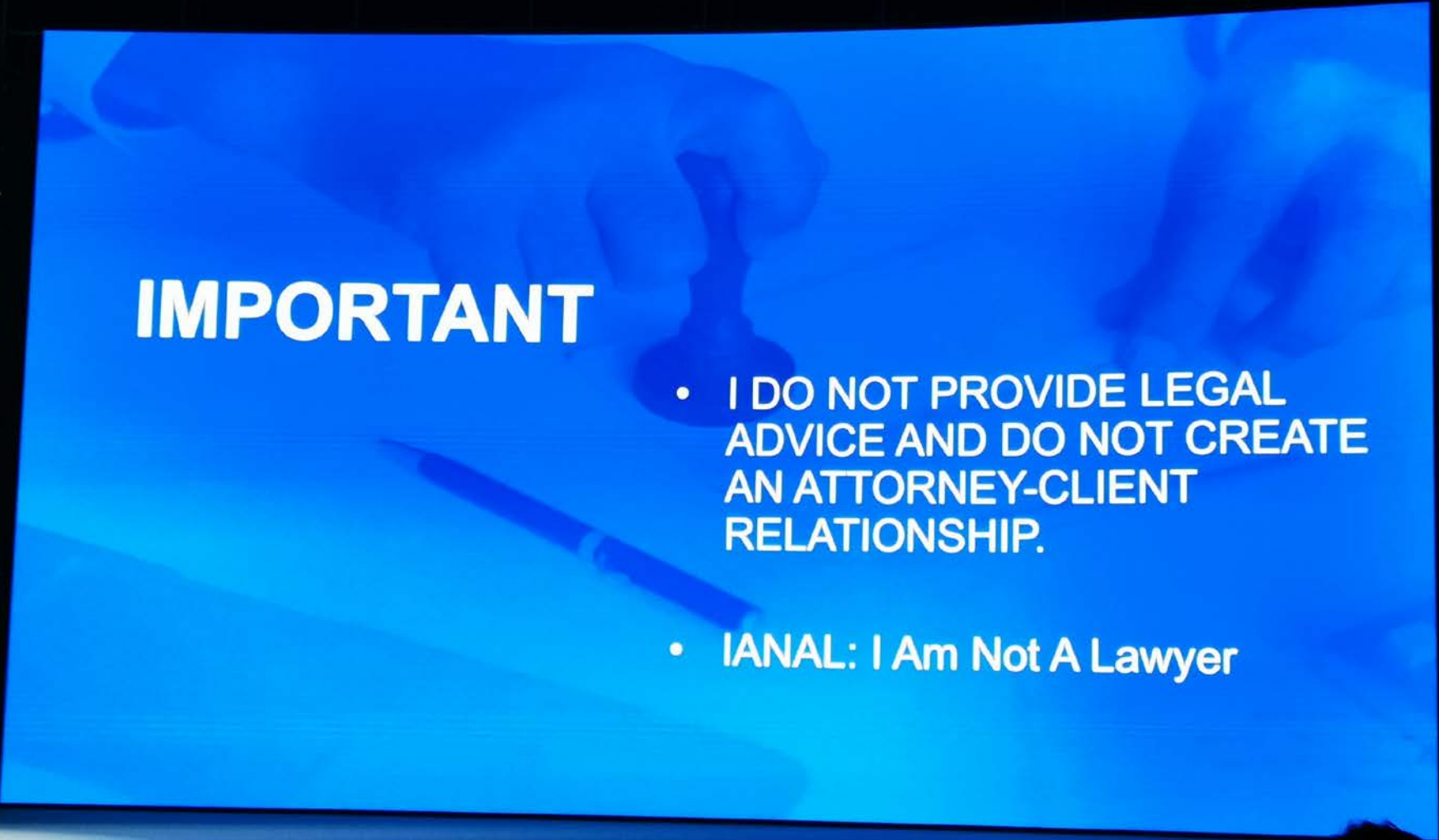
Just because your item is worth this (XXXX) amount, doesn't mean there is an active or captive buyer willing to pay for it

Market demand changes regularly

But the "High end vulnerabilities" are generally in "regular" demand



网络安全中心



IMPORTANT

- I DO NOT PROVIDE LEGAL ADVICE AND DO NOT CREATE AN ATTORNEY-CLIENT RELATIONSHIP.
- IANAL: I Am Not A Lawyer



Legal - Contracts

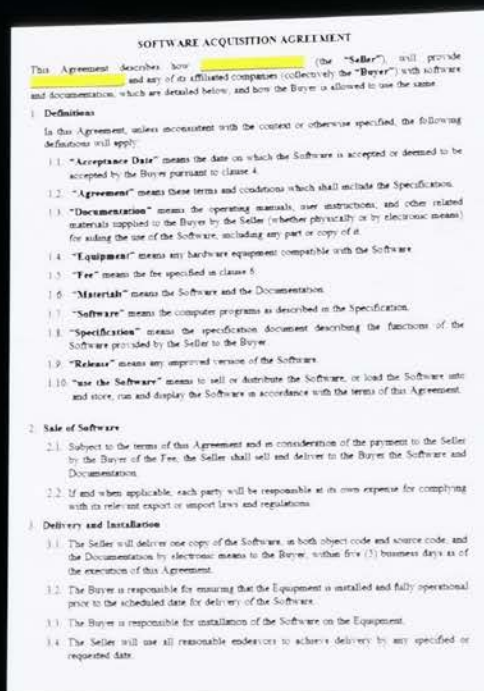
Spec

Exclusive / Nonexclusive

Delivery date

Validation period

Fees & payment



Propriety rights

Confidentiality

Support

Governing law

Export liability



第七屆國際資訊安全大會

Spec

- Bug type
- Exploit result
- Vector
- Affected architecture
- Reliability
- Execution time
- Mitigations bypass
- Supported versions
- Product configuration
- Deliverables

As a researcher, you guarantee the end result of the vulnerability on a pre-defined configuration

There is some acceptable variance with your estimates ($\pm 5\%$)



Never claim it is more reliable or capable than it is, it will end badly.

Specification

Title:

Bug type:

Exploit result:

Vector:

Affected architecture:

Exploit result:

Reliability

Execution time

Mitigation bypass:

Supported versions:

- The exploit works on the following versions:
- The vulnerability is open but not exploited on the following versions:

Process continuation:

Product configuration:

Deliverables:



安全中心



第七屆國際資訊安全大會

Validation Period

4.4 Acceptance

- 4.1 Buyer shall conduct acceptance tests of the Materials within fourteen (14) days following the delivery of the Software (the "Acceptance Date"). If before the expiration of the acceptance period the Buyer finds that the Materials do not conform to their Specification, Buyer may reject the Software by providing written notice with a description of the nonconformity to the Seller. In which case, the Seller, at its sole cost, will update the Materials to fix its failure to conform to the Specification and deliver revised Materials. Buyer will then be granted with additional seven (7) days to conduct additional acceptance tests.
- 4.2 If the Buyer uses the Software before acceptance under this clause, except for testing purposes in accordance with the acceptance tests, then the Software will be deemed to have been accepted on the date of such first use.
- 4.3 If the Buyer rejects the Software after the acceptance tests the Buyer agrees to cease all use of the Software and Materials and will promptly destroy all copies of the Software and Materials in its possession or control.

Usually 14 days

If the client has questions –
there is an extension of up
to 7 days
(Total of 21 days)

During the validation
period, the client can
decline the vulnerability if it
doesn't comply to the Spec



第七屆國際資安大會

Validation Period

4. Acceptance

- 4.1. Buyer shall conduct acceptance tests of the Materials within fourteen (14) days following the delivery of the Software (the "Acceptance Date"). If before the expiration of the acceptance period the Buyer finds that the Materials do not conform to their Specification, Buyer may reject the Software by providing written notice with a description of the nonconformity to the Seller. In which case, the Seller, at its sole cost, will update the Materials to fix its failure to conform to the Specification and deliver revised Materials. Buyer will then be granted with additional seven (7) days to conduct additional acceptance tests.
- 4.2. If the Buyer uses the Software before acceptance under this clause, except for testing purposes in accordance with the acceptance tests, then the Software will be deemed to have been accepted on the date of such first use.
- 4.3. If the Buyer rejects the Software after the acceptance tests the Buyer agrees to cease all use of the Software and Materials and will promptly destroy all copies of the Software and Materials in its possession or control.

Usually 14 days

If the client has questions –
there is an extension of up
to 7 days
(Total of 21 days)

Make sure you get access to the client test environment

Where possible, consider having a VM image ready in case you
need to ship the working state PoC

Ensure buyer is prepared to test the item before sending –
avoid anxiety

During the validation
period, the client can
decline the vulnerability if it
doesn't comply to the Spec



网络安全中心

6. Fee & Payment Terms

6.1. The Buyer shall pay to the Seller a total sum of [REDACTED] US dollars (USD [REDACTED]), plus VAT if applicable, as a fixed compensation for the Materials to be provided as part of this Agreement. The Fee shall be payable as follows:

6.1.1. an amount of [REDACTED] (USD [REDACTED]) to be paid after successful acceptance tests within seven (7) days of the Acceptance Date (the "First Installment").

6.1.2. [REDACTED] equal monthly installments of [REDACTED] US dollars (USD [REDACTED]) each, following the date of First Installment.

6.2. For the avoidance of doubt, in the event where the Software becomes either (i) part of the "public domain" due to any reason other than infringement by the Buyer of its obligations under this Agreement or misuse by Buyer's customers, or (ii) inefficient due to modifications made in the relevant software, and were implemented in a subsequent release or (iii) otherwise compromised or not functional, in whole or in part, then any remaining payment obligations of the Buyer hereunder at such time, shall be cancelled and no longer due to the Seller unless the Seller updates the Materials to fix its failure to conform to the Specification and delivers revised Materials.

6.3. The Buyer will pay to the Seller the Fee which fall due under this Agreement in the amounts and at the times specified in clause 6, against a duly issued invoice. The Buyer will deduct any withholding taxes as required by law unless Seller will present an exemption from such withholding taxes.

Fees & Payment

THERE IS NO SUCH THING AS ADVANCED PAYMENT

- Split the risk approach
- 100% on validation usually below 100k
- VAT (if applicable)
- Cryptocurrency VS Fiat
- Remember - if the transaction will be in USD (standard pricing), you should have a USD account



Propriety Rights

Exclusive

Buyer acquires any and all title, copyright, or other proprietary rights

Researchers - make sure you add to the contract the ability to use your vulnerability for internal research

Nonexclusive*

The researcher sells a license

Can be sold multiple times



Support

- Support can take many forms:
 - Exploit adjustments to:
 - Product new / older versions
 - New vectors
 - If the vulnerability is patched, the researcher may need to provide a different vulnerability
 - Provide a workshop about the vulnerability to the client

Don't Forget – Support is worth money

If you are going to provide technical support for your sale, make sure you get paid for it



Governing law

- Be mindful of where legal disputes are handled.
- Make sure you have all the licenses if something goes terribly wrong.
- Are there grounds for a suit?
- Work with reputable buyers, they have no incentive to take bad deals that lead to legal action. Reputation matters for both sides.



Wassenaar agreement

- The Wassenaar agreement on Export Controls for Conventional Arms and Dual-Use Goods and Technologies is a multilateral export control regime.
- In simple words – In some countries you need an export license.
- Each state legislates laws that represent the Wassenaar agreement differently.

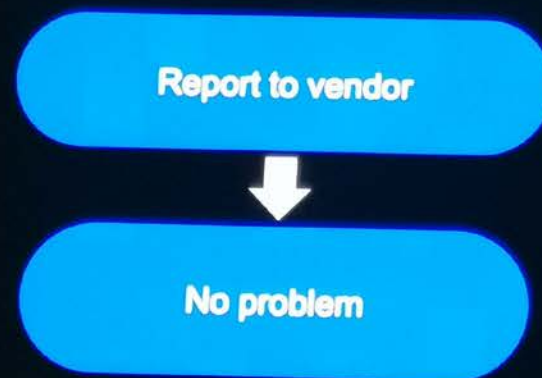
Agreement



Law



Export liability - Wassenaar

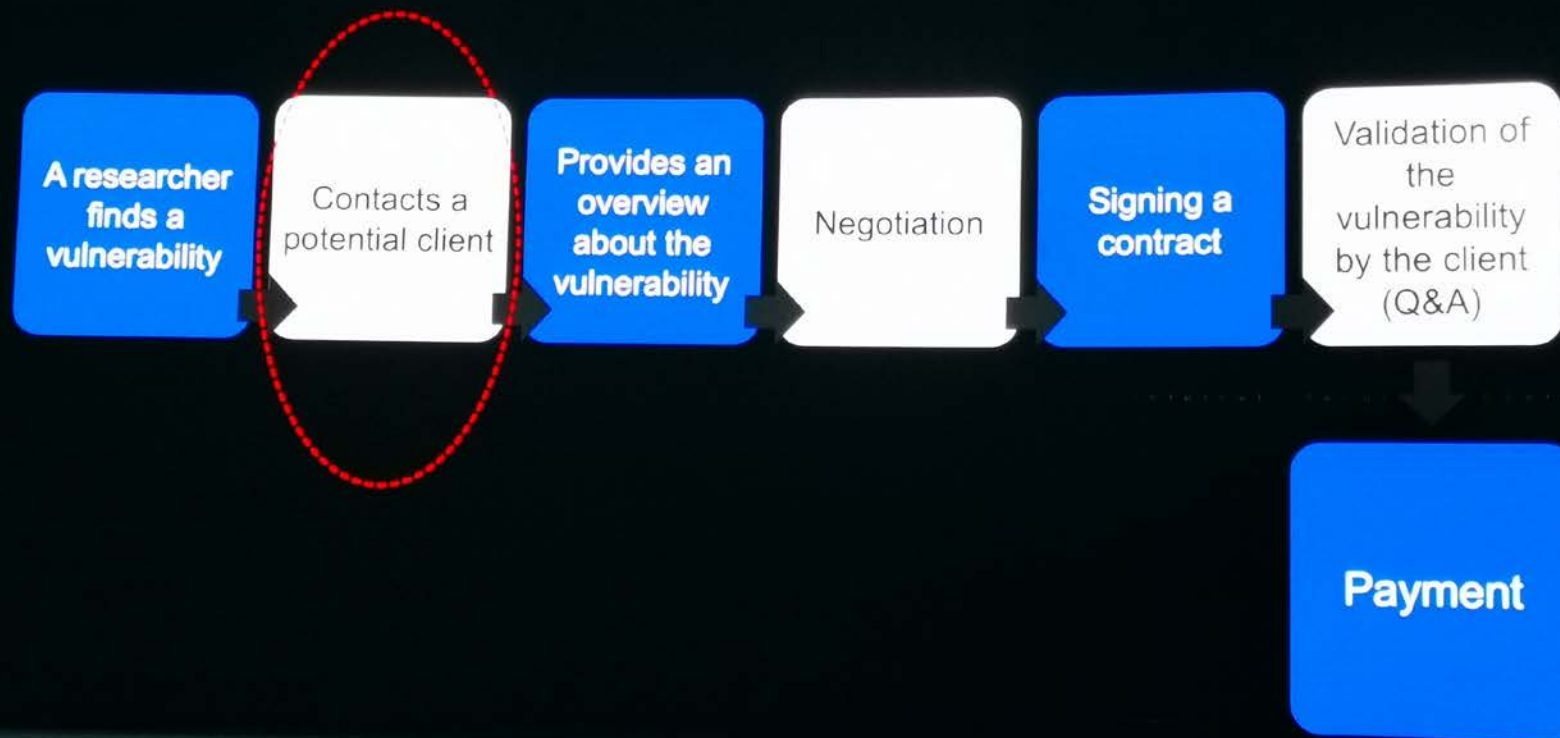




The sales process - overview



网络安全中心





Selling Vulnerabilities to Govs / Companies

Official point of
contact

Vulnerability
brokers

Personal connections
(govs / companies)





Official point of contact

- Some governments and offensive security companies publish “official” point of contact
 - Conferences (business cards / emails / flyers etc.)
 - Direct approach (“cold email”)
- As a researcher, you can email companies you think will be interested (They will probably reply)



安全中心

Official point of contact

Governments direct can be extremely time consuming



don't expect amazing terms or a timely schedule for decision making or payment

Some may be willing to engage directly unsolicited (expect significant competition)

some may be impossible to reach and need a direct relationship or introduction

Official point of contact

Pros

The researcher knows who the client is
Updated in real time on the status of the deal
Legal (licensing)

Cons

The client (usually) knows the researcher identity
Limited number of potential clients (~5)
Legal (licensing)
The researcher might get underpaid
Bad Contract
(The client can add limiting terms before buying)
Multiple POCs Simultaneously - Time consuming



Selling Vulnerabilities to Govs / Companies

Official point of
contact

Vulnerability
brokers

Personal connections
(govs / companies)

Personal connections

Pros	Cons
The researcher knows who the client is	The client (usually) knows the researcher identity
Updated in real time on the status of the deal	Limited number of potential clients (~5)
Legal (licensing)	Legal (licensing)
Full payment without worries*	The researcher might get underpaid
Trust	Bad Contract (The client can add limiting terms before buying)
	Multiple POCs Simultaneously - Time consuming



**Vulnerability
broker**





Benefits of working with brokers

Anonymity

**Market
Landscape**

**Close and
intimate
relationship
with clients**

Negotiation

Legal

**Manage the
process**

How does a broker make his money?

The broker charge the client for his services

There are couple of models:

Broker Fee - %
on top of the
initial price.

Q-recon fees
were:

- 17% from companies
- 15% from governments

Reseller - The
broker buys the
vulnerability from
the researcher
and sells it to
couple of clients

Subscription -
yearly or monthly
subscription fee.



全中心



Get Some Street Cred

- Play CTFs
- Go to Conferences – meet researchers and potential clients
- Publish 1-2 vulnerabilities (high-end)
- Get help when in doubt
- Know your s*** (Never “Fake it till you make it”).
- Don't worry about imposter syndrome or if you're good enough, you never know until you try



**How Can I Help You
on Your Journey**

I closed my company, but I still want to help.

ATM, I offer my services for free, no strings attached.



THANK YOU



@malltos92



Maor@grecon.com



小鹅助理



谢谢!

扫码添加小鹅助理，与数万科技圈人士
分享重量级活动PPT、干货培训课程、高端会议免费门票